

Audit SSI

Chapitre 5 : Méthodologies d'analyse de risques

Introduction

La gestion des risques est une **étape essentielle** dans tout processus d'audit de sécurité.

Elle vise à **identifier, évaluer et traiter les risques** susceptibles d'affecter la confidentialité, l'intégrité, la disponibilité ou la traçabilité des informations.



Pourquoi analyser les risques ?

La gestion des risques est au cœur de toute stratégie de sécurité de l'information.

Elle permet de **prioriser les efforts, optimiser les coûts de protection** et répondre aux exigences des normes comme **ISO 27001** ou **ISO 22301**.

Matrice des risques

	Gravité				
	Négligeable	Mineure	Modérée	Majeure	Catastroph
Très probable					
Probable					
Possible					
Peu probable					
Très peu probable					

Pourquoi analyser les risques ?

Dans un contexte d'audit, l'analyse des risques :

- **Cadre l'audit** en orientant le périmètre vers les zones sensibles ;
- Fournit une **base objective** pour formuler les constats et les recommandations ;
- Permet d'évaluer l'**adéquation des mesures de sécurité** mises en œuvre

Matrice des risques

	Gravité				
	Négligeable	Mineure	Modérée	Majeure	Catastroph
Très probable					
Probable					
Possible					
Peu probable					
Très peu probable					

C'est quoi analyser les risques ?

L'analyse de risque est l'évaluation des menaces et vulnérabilités qui **impacterait** la confidentialité, l'intégrité et la disponibilité des données , ainsi que leur probabilité d'occurrence.

La gestion du risque est l'implémentation des contrôles ainsi que le processus de décision amenant le risque à être **réduit** ou **éliminé**.

		IMPACT				
		Mineur	Faible	Moyen	Fort	Majeur
PROBABILITÉ	Quasi inévitable	5	10	15	20	25
	Probable	4	8	12	16	20
	Possible	3	6	9	12	15
	Faible	2	4	6	8	10
	Rarissime	1	2	3	4	5

C'est la prise en compte de l'exposition à un danger, un préjudice ou tout autre événement dommageable.

Le risque est inhérent à une situation ou à une activité : il est donc impossible de l'éliminer (dans certains cas).

C'est quoi le risque ?

Risque - Risk : effet de l'incertitude sur l'atteinte des objectifs

Risque lié à la sécurité de l'information : potentiel que des menaces exploitent des vulnérabilités d'un (groupe d')actif entraînant un impact négatif sur l'organisme.

Questions :

Que pourrait-il survenir? (Quelle est la **menace**?)

À quel point cela peut-il être négatif ? (Quel est l'**impact** ou la **conséquence**?)

À quelle fréquence cela peut-il survenir?

(Quelle est la fréquence/probabilité?)

Quel est le degré de certitude des réponses aux trois autres questions?

Le vocabulaire du risk Management

Actif / Asset: Objet ayant de la valeur (y compris, l'humain). Un asset est une ressources qui doit être protégé (Collaborateurs, Data, les bureaux, les serveurs, PC, Laptops, etc).

Menace: Entité physique ou abstraite qui met un actif à risque. C'est un événement potentiellement dommageable pour l'organisation.

Agent de menace: #menace Un agent de menace est une personne par qui la menace est exécutée, ceci de manière intentionnelle ou pas. Un hacker ou un ex-collaborateur mécontent

À quelle fréquence cela peut-il survenir?

Vulnérabilité: C'est une faiblesse qui peut être exploitée par une menace. Un Datacenter situé en sous-sol est une vulnérabilité. Un OS pas à jour.

Le vocabulaire du risk Management

Risk: Le risque est une menace associée à une vulnérabilité.

Prenons l'exemple du Datacenter et de l'OS pas à jour.

Menace tempête de pluie(inondations) dans le premier cas et un malware dans le second cas.

Les risques dans ces deux cas sont: un Datacenter inondé et un OS compromis au niveau CIA.

La formule mathématique du risque est la suivant:

Risque = Menace x Vulnérabilité

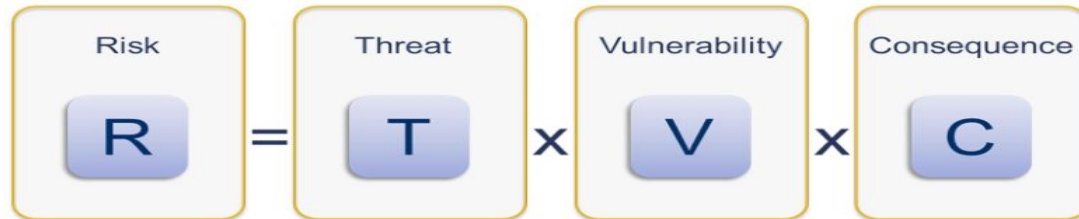
RISK = THREATS x CAPACITIES VULNERABILITIES

Le vocabulaire du risk Management

Impact: L'impact est la conséquence financière d'un événement, la plupart du temps exprimé en devise.

Il peut être très pertinent d'analyser l'impact financier d'un risque , d'où le fait, dans certains cas le risque est exprimé ainsi:

Risque = Menace x Vulnérabilité x Impact



Le vocabulaire du risk Management

Impact: L'impact est la conséquence financière d'un événement, la plupart du temps exprimé en devise.

Il peut être très pertinent d'analyser l'impact financier d'un risque , d'où le fait, dans certains cas le risque est exprimé ainsi:

$$\text{Risque} = \text{Menace} \times \text{Vulnérabilité} \times \text{Impact}$$

*La perte de vie humaine est considéré par (ISC)² comme étant un impact infini.
Donc celui qui implique la perte de vie humaine sera toujours le plus grand.*

Étapes de gestion des risques

2.1. Identification des risques

- Recensement des **actifs critiques** (applications, bases de données, ressources humaines, procédures, etc.)
- Identification des **menaces** (internes, externes, accidentelles, malveillantes)
- Analyse des **vulnérabilités** (techniques, organisationnelles, humaines)

Étapes de gestion des risques

2.2. Analyse et évaluation des risques

- Estimation de l'**impact potentiel** (perte financière, atteinte à l'image, non-conformité réglementaire)
- Estimation de la **probabilité d'occurrence** d'un scénario de menace
- Classement par **niveau de criticité** (risque net, risque brut)

Étapes de gestion des risques

2.3. Traitement des risques

- **Réduction** : mise en place de mesures de sécurité préventives ou correctives
- **Transfert** : recours à des assurances ou à des tiers (externalisation)
- **Acceptation** : risque jugé tolérable selon le contexte métier
- **Évitement** : arrêt ou modification de l'activité à risque

Étapes de gestion des risques

2.4. Suivi et revue des risques

- Vérification de l'efficacité des mesures
- Mise à jour des scénarios
- Intégration dans une **démarche d'amélioration continue (PDCA)**

Technique d'analyse des risques

Quantitative Risk Analysis: Avec cette méthode il s'agit d'utiliser des quantités, des informations numériques c'est-à-dire déterminer le coût. Elle est objective mais longue et difficile pour celui ou celle qui l'utilise correctement.

La méthode quantitative de l'analyse de risques fait appel aux instincts purement pécuniaires de l'entreprise, puisqu'il s'agit d'attribuer une valeur monétaire à chaque composante du risque, ainsi qu'aux pertes potentielles.

Le gros avantage de cette méthode est que la prise de décision est grandement facilitée, car les retours sur investissement et les pertes potentielles sont comparables à la même échelle.

Technique d'analyse des risques

Qualitative Risk Analysis: Dans certains cas cela peut être complexe pour apprécier avec des chiffres, vous devez utiliser donc la méthode qualitative. Ici il s'agit d'évaluer le risque avec notes ou scorings ou ratings. Elle n'est pas scientifique mais a le mérite de permettre de calculer un risque impossible à calculer. Elle est subjective. Vous allez utiliser approximation basée sur l'expérience.

alors vous aurez une note attribuée à chaque risque. Vous allez associer chaque note à une fourchette de perte financière .

Note de 1 à 5. avec une terminologie Low, Medium, High et Very High. Une fourchette 100,00 à 1 M pour un risque Low

Technique d'analyse des risques

Qualitative Risk Analysis:

La méthode qualitative utilise des scénarios de risques qui sont construits en attribuant aux menaces, vulnérabilités et impacts potentiels une échelle de valeur.

Il s'agit de calculer un risque et de recommander des mesures appropriées.

C'est une méthode qui est facilement compréhensible par tous et qui a l'avantage de s'adapter à tout type de scénario.

Technique d'analyse des risques

Hybrid Risk Analysis: C'est simplement la combinaison des deux précédentes méthodes. Dans un projet vous pourrez être confrontés à plusieurs risques.

Certaines peuvent être calculé plus ou moins facilement et d'autres non.

Cette approche permet d'avoir une analyse la plus précises possible.